Организационное обеспечение защиты информации

Соколов В.Е.

Организация защиты информации

- Организации должны оценивать не только **угрозы** которые могут действовать через уязвимости но и **риски**, т.е. вероятность наступления событий которые могут нанести какой-либо ущерб или убыток.

- К сожалению риск-ориентированные подходы сегодня не работают. Так как сегодня отсутствует основной элемент формулы риска – **вероятность его наступления**

Организация защиты информации

- Анализ рисков или оценка вероятности их наступления, а также тяжести последствий похожа на посещение игроками Лас-Вегаса – зал общий, а система игры у каждого своя





Организация защиты информации

- Методики оценки рисков предоставляются многими консультантами (*которые заинтересованы в продаже своих продуктов…*)

- По каким критериям выбрать лучшую методику управления рисками?
  1. Она должна быть полезной? Соответствовать требованиям к принятию решений? Отвечать на мои вопросы?
  2. Должа быть логичной? Она измеряет именно риски? Она оценивает частоту угроз и размер ущерба?
  3. Она соответствует действительности?

Организация защиты информации

- Управление рисками сегодня сродни шаманству, это больше искусство, чем наука
  - Управление рисками похоже на шаманство
    - Битьё в бубен, бросание костей – отсутствие рационального объяснения своего выбора
    - Заветы предков или Лучшие практики
    - Интуиции, опыт, чутьё и т.д.





Организация защиты информации

- Обычная схема определения вероятности наступления риска оценивается двумя подходами:

  – оценка по фактам,

  – оценка по ощущениям (она же экспертная).

Организация защиты информации

- Первый метод (оценка по фактам), базирующийся на статистике, к сожалению не работает в бизнесе и промышленности, так как статистика инцидентов почти отсутствует или стремится к нулю.

- Строить адекватную картину на статистике инцидентов не получается. Отсюда первый вывод - классическая **оценка рисков по статистике** (она кстати активно применяется страховыми компаниями) в промышленной ИБ **не работает**.

- Пока не работает. Возможно, со временем ситуация изменится, число инцидентов будет расти (*не хотелось бы*), и тогда появится адекватная оценка вероятности происходящего.

Организация защиты информации

- Второй подход (экспертный) работает также плохо, так как согласно психологии восприятия рисков человеку свойственно принижать проблемы, с которыми он не сталкивался.

- А промышленность, почти не сталкиваемся с серьезными инцидентами ИБ в своей практике, а если они и происходят, то мы считаем их случайностью.

Организация защиты информации

- Если же инциденты случаются у наших коллег, то вступает в игру другое следствие из психологии восприятия рисков - предубеждение оптимизма, то есть классическое "*с нами такого не случится*" (достаточно вспомнить, сколько людей страхует свою жизнь, квартиру и т.п.).

- Второй вывод тоже прост - пока **экспертная оценка работает тоже не очень хорошо**.

Организация защиты информации

- И вот тут можно сделать следующий вывод – **государство должно вмешаться и регулировать** эту тему, так как бизнес сам не готов вкладывать в то, что может никогда не произойти или произойти с очень малой вероятностью. Но... не просто вмешаться, а сделать это грамотно и осмысленно. Для этого надо:

  - привлекать экспертное сообщество (из разных отраслей) до принятия каких-то управленческих решений
  - разработать понятные и дифференцированные критерии категорирования критических инфраструктур
  - разработать решения, которые учитывают отраслевую специфику
  - (самое главное) предоставить переходный период на реализацию разработанных требований.

Организация защиты информации

- Риск описывается комбинацией следующих элементов:
  - Тяжесть возможного ущерба (последствия)
  - Вероятность нанесения ущерба
  - Частота и продолжительность воздействия угрозы
  - Вероятность возникновения угрозы
  - Возможность избежать угрозы или ограничить ущерб от нее

- Эффективность управления рисками зависит от того, сможем ли мы оценить эти элементы

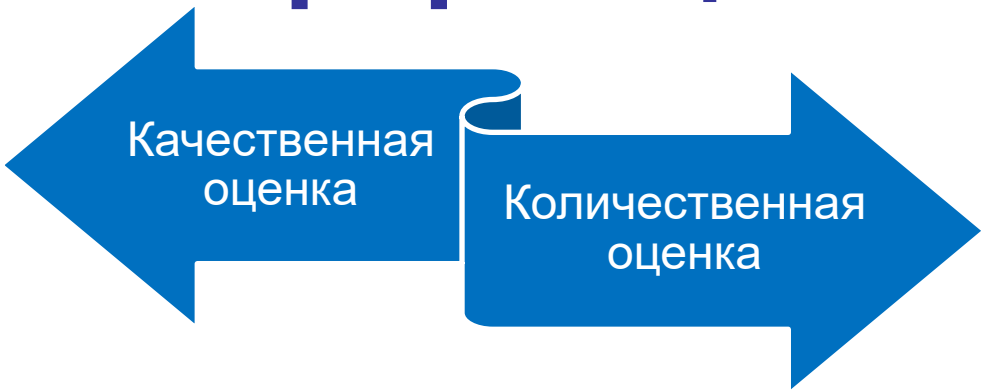
Организация защиты информации

- Как оценить риск, качественно или количественно?

- Что лучше:
  - наступление риска в 136 случаях из 144

    или
  - наступление риска очень вероятно?!

Организация защиты информации



- Количественная оценка работает лучше экспертной (качественной)
  - — Качественная оценка необъективна по своей сути
  - — При качественной оценке сложно предъявить доказательства

- Отсутствие количественной оценки не позволяет
  - — Оценить адекватность затрат на снижение рисков
  - — Оценить возможность перекладывания рисков
  - — Продемонстрировать снижение рисков
  - — Сравнить текущий уровень с предыдущими значениями

Организация защиты информации

- Количественная оценка не всегда возможна из-за
  - Недостатка информации о системе
  - Недостатка информации о деятельности, подвергающейся оценке
  - Отсутствии или недостатке данных об инцидентах
  - Влияния человеческого фактора

- Качественная оценка требует
  - Четкого разъяснения всех используемых терминов
  - Обоснования всех классификаций частот и последствий
  - Понимания всех плюсов и минусов качественной (экспертной) оценки

Организация защиты информации

- Даже **при наличии фактов** и достаточного объема информации об анализируемой системе у экспертов существует **сложность с восприятием риска**
- **Безопасность основана** не только на вероятности различных рисков и эффективности различных контрмер (реальность), но и **на ощущениях**
- Ощущения зависят от психологических реакций на риски и контрмеры
  - Чего вы больше опасаетесь – попасть в авиакатастрофу или автоаварию?
  - Что вероятнее – пасть жертвой террористов или погибнуть на дороге?

Организация защиты информации

- Реальность безопасности ≠ ощущения безопасности

- Система может быть безопасной, даже если мы не чувствуем и не понимаем этого
  - Мы можем думать, что система в безопасности, когда это не так

Организация защиты информации

- Число погибших в авиакатастрофах в России в 2023 году – 20 человек
  2024 году – 64 человек
  1980 – 1989 гг. – в СССР 2624 жертвы авиакатастроф
- Трагедия 11 сентября в США унесла жизни 2973 человек
- Число жертв автоаварий в России – около 100 человек ежедневно (!)
  - 1,2 млн. жертв в год, 20 - 50 млн. получают травмы
- От отравления пищей в США ежегодно умирают 5000 человек



Организация защиты информации

- Мы преувеличиваем одни риски и преуменьшаем другие

- Наше восприятие риска чаще всего «хромает» в пяти направлениях
  - Степень серьезности риска;
  - Вероятность риска;
  - Объем затрат;
  - Эффективность контрмер;
  - Возможность адекватного сопоставления рисков и затрат;

Организация защиты информации

- В человеческом мозгу 2 системы отвечают за анализ рисков

- **Примитивная** (интуитивная) – работает быстро
- **Продвинутая** (аналитическая) – принимает решения медленно

- Обе системы работают одновременно и конфликтуют между собой

Организация защиты информации

- Риски, имевшие место когда - либо в жизни эксперта, имеют больший вес, чем те, с которыми он никогда не встречался



- Чем более выдающимся кажется событие, тем выше вероятность, что оно покажется случайным



Организация защиты информации

- Анализ риска не может быть осуществлен без оценки потерь.
  - Без потерь рисков не бывает

- Оценка риска не имеет смысла, если мы не можем определить ценность актива, подверженного рискам

- Информационный актив может иметь разную ценность.
  - В разное время, для разных аудиторий, в разных бизнес - процессах

Организация защиты информации

- Ценность относительна

- Ценность стакана воды в городских условиях равна нулю

- Вода есть везде



- Стакан воды в пустыне бесценен

- Воды практически нет

- Цена стакана воды одинакова в обоих условиях